Seguridad en Redes y Análisis Inteligente de Amenazas

Tema 8. Protocolos de Seguridad

Índice

Esquema

Ideas clave

8.1. Introducción y objetivos

8.2. IPSec

8.3. SSL/TLS

8.4. Referencias bibliográficas

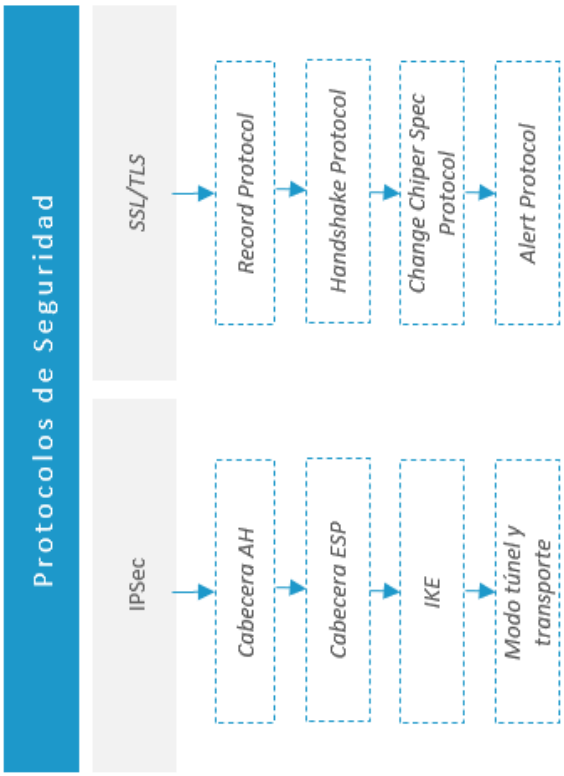
A fondo

Anatomy and Performance of SSL Processing

IPSec: Performance Analysis and Enhancements

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

8.1. Introducción y objetivos

Esta unidad pretende mostrarte los distintos protocolos que hacen posible realizar un intercambio de información seguro a través de Internet. Todos los protocolos tienen una **fuerte base criptográfica.**

Estos protocolos proporcionan uno o varios de los **servicios de seguridad.** Por ejemplo, la confidencialidad de la información que la hace inteligible para posibles atacantes, la autenticación del emisor/receptor del mensaje para verificar su identidad. La autenticación de los extremos de la comunicación cobró una especial importancia con el incremento del comercio electrónico. De esta manera, se asegura que el emisor/receptor del mensaje es quién dice ser (es importante para evitar casos, por ejemplo, de *phising* o fraudes bancarios).

Existen múltiples protocolos que, haciendo uso de algoritmos criptográficos, permiten establecer un canal de comunicación seguro para el intercambio de información, entre los que están el protocolo IPSec y el protocolo SSL que serán estudiados en este tema.

© Universidad Internacional de La Rioja (UNIR)

8.2. IPSec

IPsec [RFC4301] es un estándar que incorpora los servicios de seguridad apropiados a nivel de red. Dichos servicios tienen por objetivo proporcionar confidencialidad, integridad y autenticación de las comunicaciones en dicho nivel. El uso de IPsec es opcional en IPv4 y, aunque fue obligatorio en las primeras versiones del estándar IPv6, recientemente, y para casos muy concretos, se ha permitido que sea opcional.

Asociación de seguridad

Una **Asociación de Seguridad (SA - *Security Association*)** es una relación entre dos o más entidades que describe cómo estas utilizarán los servicios de seguridad para comunicarse de forma segura. Se trata de un acuerdo entre las partes, y en el que se establecen aspectos como los algoritmos de cifrado, la duración de la asociación, el método de autenticación, etc.

Los protocolos de seguridad requieren la negociación de una serie de parámetros que permitan el empleo de estos de manera adecuada. La asociación de seguridad es la unidad básica de negociación que permite la especificación de las particularidades de los servicios de seguridad.

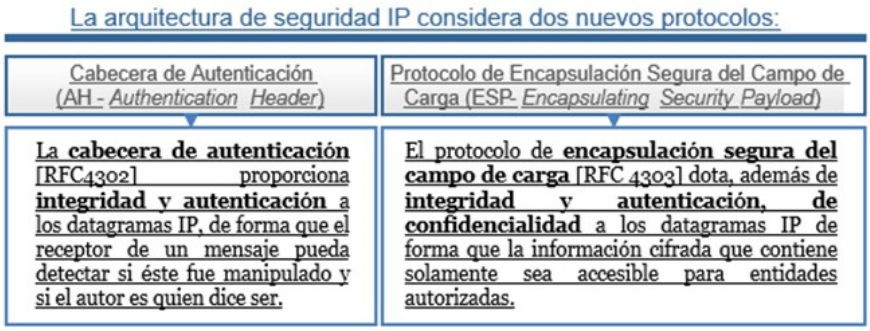


Figura 1. Protocolos de la arquitectura de Seguridad IP. Elaboración Propia.

© Universidad Internacional de La Rioja (UNIR)

Cabecera de Autenticación: Protocolo AH

La **cabecera de autenticación AH** es un protocolo que proporciona mecanismos de autenticación e integridad a los datagramas IP. Los datos de autenticación son colocados tras la cabecera original del datagrama IP; así, los sistemas que no estén participando en la autenticación pueden ignorar tales datos y encaminar convenientemente dichos paquetes.



Figura 2. Localización de la cabecera AH en una trama. Elaboración Propia.

El rendimiento de la comunicación se verá mermado tanto en el lado del remitente como en el del destinatario, que debe verificar cada datagrama IP que contenga una cabecera AH.

Los **datos de autenticación** se calculan sobre el paquete entero, salvo aquellos campos de la Cabecera IP que son modificados durante el camino, como el TTL. Es necesario que ambos extremos de la comunicación acuerden las características que van a regir dicha comunicación de forma segura, estableciendo para ello una asociación de seguridad. En este caso y en el de ESP, las asociaciones de seguridad son unidireccionales, es decir, se establece al menos una asociación de seguridad para cada sentido de la comunicación entre los extremos de esta. Estas pueden ser renovadas a lo largo de la conexión.

La cabecera de autenticación tiene el siguiente **formato:**

© Universidad Internacional de La Rioja (UNIR)

Next Header	Payload Length	Reserved
Security Parameter Index		
Sequence Number Field		
Authentication Data		

Figura 3. Cabecera de Autenticación. Elaboración Propia.

- **Next Header:** tipo de cabecera a continuación de esta.
- **Payload Length:** tamaño de la cabecera en palabras de 32 bits.
- **Reserved:** espacio reservado para usos futuros.
- **Security Parameter Index (SPI):** representa a un número pseudoaleatorio de 32 bits que identifica a una determinada asociación de seguridad (SA). El índice SPI, con la dirección destino IP y el protocolo de seguridad (AH), identifican unívocamente a la asociación de seguridad para este datagrama.
- **Sequence Number:** previene frente a posibles ataques de reenvío.
- **Authentication Data:** porta el código de autenticación del contenido siguiente. El mecanismo generalmente utilizado es la autenticación mediante un algoritmo de función resumen con clave.

El remitente deberá identificar la asociación de seguridad apropiada que indique el algoritmo, la clave y cualquier otro parámetro de seguridad necesario. El remitente calcula la información de autenticación, y la coloca en el campo de carga de la cabecera AH y envía el paquete a su destino. El destinatario recibe el paquete,

© Universidad Internacional de La Rioja (UNIR)

localiza la asociación de seguridad correcta y comprueba la consistencia del campo de datos de autenticación. Si el proceso indica que el datagrama es válido, este es aceptado.

Encapsulación segura del campo de carga: Protocolo ESP

La **cabecera ESP** permite establecer un mecanismo para dotar del **servicio de confidencialidad en la capa de red (nivel IP),** además de los de integridad y autenticación que aportaba la cabecera AH. Esto es posible gracias al cifrado de los datos. El protocolo soporta *encryption-only* y *authentication-only* en caso de que solamente se quiera hacer uso de un servicio de seguridad particular. La localización de un ESP en una trama puede verse en la siguiente figura.

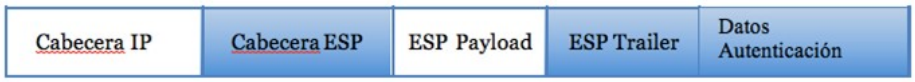


Figura 4. Localización ESP en una trama. Elaboración Propia.

Es necesario, al igual que en AH, que ambos extremos de la comunicación acuerden las características que van a regir dicha comunicación de forma segura: **deben establecer al menos una asociación de seguridad para cada sentido de la comunicación.** Al igual que en AH, estas pueden ser renovada a lo largo de la conexión.

El coste computacional del cifrado y descifrado de cada paquete IP es mayor que en el caso de la cabecera AH, y en determinados sistemas esto puede acarrear problemas de rendimiento.

La cabecera ESP tiene el siguiente **formato:**

© Universidad Internacional de La Rioja (UNIR)

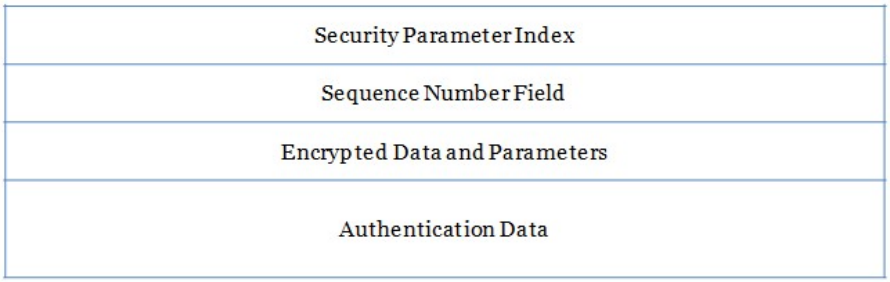


Figura 5. Cabecera ESP. Elaboración Propia.

- **Security Parameter Index (SPI):** representa a un número pseudoaleatorio de 32 bits que identifica a una determinada asociación de seguridad. El índice SPI, con la dirección destino IP y el protocolo de seguridad (ESP), identifican unívocamente a la asociación de seguridad para este datagrama.
- **Sequence Number:** previene frente a posibles ataques de reenvío.
- **Encrypted Data and Parameters:** contiene un campo vector de inicialización, y la información cifrada de los protocolos superiores.
- **Authentication Data:** Valor que permite la comprobación de la autenticación y la integridad del paquete ESP. Este control incluye el ESP tráiler, ESP payload y la cabecera ESP, pero no tiene en cuenta la cabecera IP ni el propio campo Authentication Data.

El SPI y el *sequence number* van en la cabecera ESP, el ESP tráiler contiene el *padding*, la longitud de este y el siguiente protocolo del paquete y, por último, van colocados los datos de autenticación de ESP. El ESP payload y el ESP tráiler van cifrados y la autenticación, aparte de estas dos partes, también incluye la Cabecera ESP.

© Universidad Internacional de La Rioja (UNIR)

Protocolos ISAKMP e IKE

E l **protocolo ISAKMP (*Internet Security Association and Key Management Protocol*)** fue propuesto por el IETF y describe un **marco seguro de negociación para el desarrollo de protocolos de seguridad.** Una de sus motivaciones es la de afianzar la utilización de las asociaciones de seguridad en el contexto de la arquitectura IPSec, permitiendo la gestión y el establecimiento de las asociaciones de seguridad. Por así decir, el protocolo ISAKMP define procedimientos y formatos de los paquetes para establecer, negociar, modificar y eliminar estas asociaciones de seguridad. Proporciona una alternativa al intercambio manual de claves.

Una implementación concreta de ISAKMP es el protocolo **IKE (*Internet Key Exchange*)** y tiene como objetivo la negociación y gestión de los parámetros específicos de seguridad. En la actualidad, IKE ha tenido tales dimensiones de implantación que ha relevado en el nombre al protocolo original (ISAKMP). La IETF recientemente ha presentado una versión mejorada, IKEv2, descrita en los RFC4306 y RFC4307.

Para la creación de un canal seguro IPSec, el protocolo IKE debe tener lugar en primer término como elemento de acuerdo y negociación previo entre extremos del canal seguro IPSec. Tras esto, ambos extremos dispondrán de todos los elementos de seguridad necesarios para el establecimiento del canal seguro. Cuando se establece el canal seguro, el flujo de información a través de Internet queda debidamente protegido.

IKE es un **protocolo en dos fases:**

- **IKE Fase 1.** En esta fase, los dos extremos establecen una clave de sesión (clave de sesión IKE, SA ISAKMP), a partir del acuerdo de un secreto maestro, y se autentican mutuamente. Los detalles de esta comunicación pueden verse en la

© Universidad Internacional de La Rioja (UNIR)

siguiente figura:

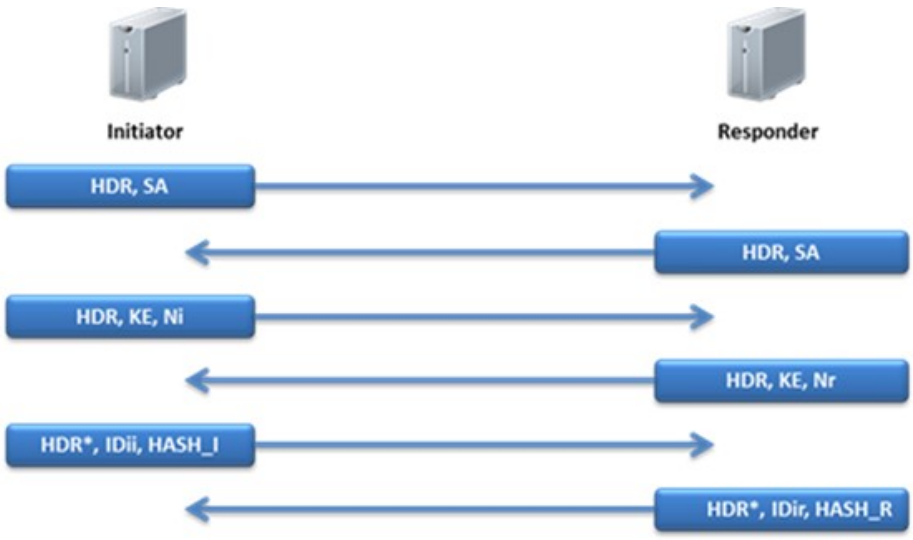


Figura 6. IKE Fase 1. Elaboración Propia.

- **Negociación de parámetros IKE** propuesta-selección. En este paso, correspondiente a los dos primeros mensajes de la figura anterior, queda acordada una asociación de seguridad (SA ISAKMP) que regirá en esta fase.
- **Intercambio de material clave (o criptográfico) mediante algoritmos de acuerdo de clave Diffie-Hellman.** Se corresponde con los mensajes tres y cuatro de la figura anterior.
- **Derivación de claves de sesión IKE a partir del secreto maestro obtenido del material criptográfico anterior.** Paso llevado a cabo tras la recepción de los mensajes tres y cuatro en cada extremo respectivamente y antes de empezar la autenticación del mensaje quinto y sexto.
- **Mutua autenticación de los extremos.** Este proceso de autenticación queda protegido mediante el cifrado con la Clave de Sesión IKE. Mensajes quinto y sexto

© Universidad Internacional de La Rioja (UNIR)

de la figura anterior.

En esta fase 1 de IKE pueden darse dos modos de funcionamiento: el **modo principal (*main*),** representado en la figura anterior, que exige la identificación protegida de ambas partes y, por tanto, resulta más seguro; o puede configurarse en **modo agresivo (*aggressive*)** que obvia este paso, y su uso no es recomendado en escenarios críticos. En el modo agresivo se intercambian solamente tres mensajes: los dos primeros que van en claro (el segundo contiene, entre otros datos, el HASH_R que sirve para autenticar al destinatario) y el tercero que ya va protegido y que sirve para autenticar al remitente. Debido a que el HAS_R va en claro, dicho *hash* puede ser analizado y por ello este modo es considerado menos seguro que el modo principal.

- **IKE Fase 2.** En esta fase se establece una nueva negociación de asociaciones de seguridad mediante propuesta-selección (asociación de seguridad IPSec), que se realiza con plenas garantías una vez que la fase 1 ha culminado y, por tanto, una clave de sesión protege esta comunicación. Los detalles de esta comunicación pueden verse en la siguiente figura:

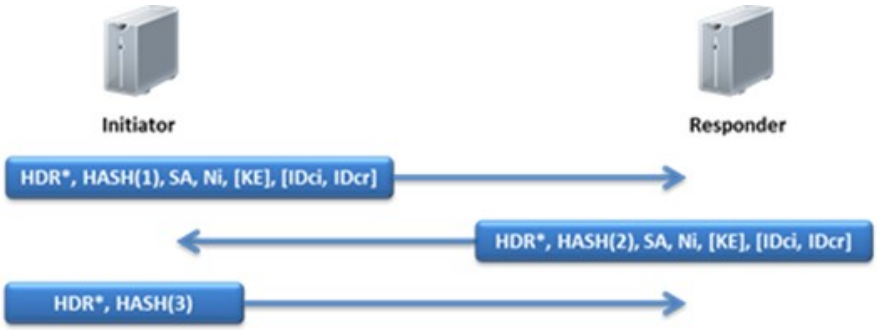


Figura 7. IKE Fase 2. Elaboración Propia.

© Universidad Internacional de La Rioja (UNIR)

- Propuesta-selección de los parámetros de seguridad.
- Intercambio de material criptográfico para la derivación de la nueva clave.
- Periódicamente, se produce la renegociación de las asociaciones de seguridad IPSec.

En la fase 2 no se produce la autenticación de las partes, ya que fueron autenticadas en la fase anterior, por lo que se suele decir que esta segunda fase se desarrolla en **modo rápido (*Quick*).**

Una vez concluida esta fase, el canal seguro IPSec queda establecido y todo el tráfico de datos entre los dos extremos de la comunicación se transmitirá de forma segura a través de Internet.

Modos IPSec

IPsec puede ser usado para establecer un canal de comunicación seguro entre dos *gateways* o entre dos *hosts*. En función de esto existen **dos modos en IPSec:**

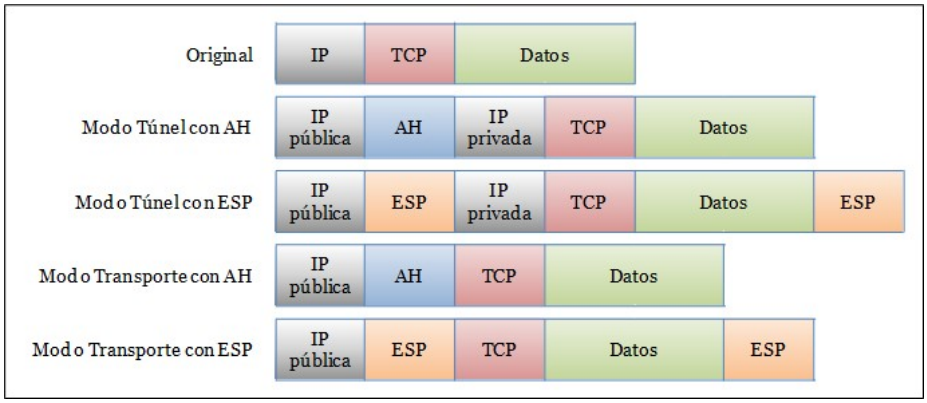
- **Modo túnel.** El termino túnel no es exclusivo de la tecnología IPSec, sino que además puede darse en distintos niveles de la pila de protocolos e implementarse sobre mecanismos de diversa naturaleza. Los túneles IPSec son túneles de capa red. El modo túnel se utiliza cuando se quiere asegurar una zona de una red y, por tanto, los dispositivos que aseguran la comunicación no son los dispositivos finales que envían/reciben datos. Es el modo más extendido en la implementación de VPN. El modo túnel consiste generalmente en encapsular el paquete IP con cabeceras

© Universidad Internacional de La Rioja (UNIR)

IPSec. Un paquete protegido con IPSec en modo túnel posee dos cabeceras IP, la cabecera interna, y la cabecera externa. La interna es generada por la pila TCP/IP, mientras que la externa la provee el dispositivo que implementa IPSec. El modo túnel puede ser usado perfectamente por dispositivos finales (*hosts*), pero no posee ninguna ventaja con respecto al modo transporte puesto que añade una cabecera IP extra que sobrecarga el protocolo.

- **Modo transporte.** El modo transporte consiste en proteger la cabecera del nivel de transporte. Los protocolos IPSec AH y ESP interceptan los paquetes que fluyen desde el nivel de transporte al nivel de red para proveer las propiedades de seguridad. El flujo original de un paquete IP cuando IPSec no está funcionando es que el paquete TCP o UDP pase de la capa de transporte a la capa de red, donde se le añade la cabecera IP, para posteriormente ser enviado a la capa de enlace. Cuando se utiliza IPSec, se produce una fase intermedia en el que se le añaden las cabeceras AH y/o ESP. El modo transporte es utilizado cuando se quieren asegurar las comunicaciones extremo a extremo.

En la siguiente figura podemos ver algunos ejemplos de diferentes combinaciones posibles de modos y protocolos.



© Universidad Internacional de La Rioja (UNIR)

Figura 8. Diferentes combinaciones de modos y protocolos Elaboración Propia.

En el vídeo, *Ataques a IPSec*, se analizan los principales ataques publicados al protocolo.

© Universidad Internacional de La Rioja (UNIR)

8.3. SSL/TLS

Secure Socket Layer **(SSL)** fue desarrollado por Netscape. La versión 1.0 no llegó a ser publicada y la versión 2.0 que fue publicada en 1995 contenía demasiados agujeros de seguridad, lo que la llevó a ser rápidamente sustituida en 1996 por la versión 3.0. Más tarde, la **Internet Engineering Task Force (IETF)** formó un grupo de trabajo con el fin de estandarizar el protocolo.

En 1999, el grupo de trabajo del IETF introdujo algunas mejoras en SSLv3, dando lugar a la primera versión del **protocolo *Transport Layer Security* (TLS),** que podría considerarse la versión 3.1 de SSL. De TLS se han publicado las versiones 1.0, 1.1, 1.2 y 1.3. En la actualidad las versiones que están recomendadas para su uso son la 1.2 y la 1.3.

Arquitectura SSL

SSL proporciona **autenticación, integridad y confidencialidad** de la información entre los extremos de una comunicación a través de mecanismos criptográficos.

Habitualmente solo el servidor es autenticado, y mediante esta autenticación, se establece un canal confidencial, mientras que el cliente se mantiene sin autenticar. SSL también proporciona autenticaciones mutuas, pero estas opciones de autenticación suelen darse en ambientes más pequeños o aplicaciones con pocos usuarios, porque a gran escala se requeriría del funcionamiento de una PKI en ambientes tan amplios como Internet. Aunque menos común, también se pueden usar algoritmos criptográficos anónimos, que permiten que el servidor no sea autenticado. Sin embargo, estos algoritmos suelen estar deshabilitados y en muchas implementaciones del protocolo no están ni incluidos.

Se detallan, a continuación, las **principales fases de SSL.**

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- **Autenticación del servidor.** Se lleva a cabo al inicio del protocolo por medio del envío de la clave pública del servidor, en el certificado X.509 que se envía al establecer la conexión, junto con su firma digital. El certificado del servidor debe ser validado por los usuarios. Generalmente los sitios web que utilizan SSL tienen sus certificados firmados por autoridades certificadoras válidas.

- **Confidencialidad e integridad de los datos.** Una vez que el usuario ha recibido la clave pública del servidor la usará para enviar de forma segura el material criptográfico necesario para poder generar la clave de sesión.

- **La autenticación del usuario.** Consiste en una firma digital generada por el usuario haciendo uso de la clave privada y del envío de su clave pública por medio de un certificado X.509. Esto es opcional, y requiere que el servidor web pueda validar este certificado. Esta opción es útil en sistemas donde la cantidad de usuarios a autenticar por sitio es pequeña. No se utiliza en aplicaciones como correo seguro, comercio electrónico, etc., ya que su dominio de usuarios es muy amplio.

Existen también en SSL un par de conceptos importantes descritos en la especificación del protocolo: **sesión y conexión.**

- **Sesión.** Creadas por el protocolo *handshake* entre cliente y servidor. Definen los parámetros criptográficos de seguridad para múltiples conexiones, lo que permite

© Universidad Internacional de La Rioja (UNIR)

evitar la renegociación de los parámetros en cada conexión. Cada sesión tiene asociado un identificador de sesión, un certificado de la entidad par (certificado X.509, opcional), un método de compresión, una especificación del cifrado (cifrador simétrico, algoritmo de hash para el cálculo del MAC (*Message Authenticaction Code*) y tamaño de la clave), clave maestra (48 bits compartidos por cliente y servidor) y si la sesión es reanudable (se puede usar para futuras conexiones).

- **Conexión.** Transporte que ofrece algún servicio y que está asociado a una sesión. Una conexión tiene asociado valores aleatorios compartidos por cliente y servidor, clave secreta para MAC de escritura del servidor, clave secreta para MAC de escritura del cliente, clave de escritura del servidor, clave de escritura del cliente, un vector de inicialización y los números de secuencia de los mensajes enviados/recibidos.

SSL es un protocolo de dos niveles (Ilustración 11) que se sustenta en el protocolo TCP. SSL está ubicado **entre la capa de transporte y la capa de aplicación.** De esta forma, protocolos de servicio como HTTP, FTP, POP3, IMAP, entre otros, pueden hacer uso de SSL para proporcionar seguridad a sus transacciones.

La primera capa de SSL, ***SSL Record Protocol,*** se usa para encapsular los protocolos de nivel superior, tanto los propios de SSL como los de la capa de aplicación superior. La segunda capa está compuesta por los protocolos de SSL. El **protocolo *Handshake*** consta de los mensajes necesarios para establecer una comunicación SSL, la autenticación del servidor, del cliente, y la negociación de las herramientas criptográficas, algoritmos y claves de cifrado, etc. El protocolo **Change Cipher Spec** sirve para indicar al otro extremo de la conexión que se está listo para empezar a utilizar el material generado durando la ejecución del protocolo

© Universidad Internacional de La Rioja (UNIR)

handshake. El **protocolo Alert** nos permite enviar mensajes de alerta al otro extremo.

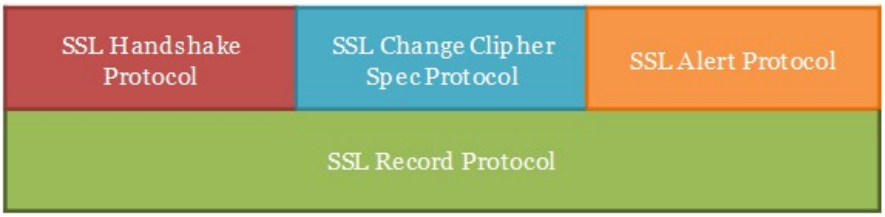


Figura 9. Capas de SSL. Elaboración Propia.

SSL Record Protocol

Este protocolo proporciona dos servicios a la conexión SSL: **confidencialidad,** a partir del protocolo *Handshake* que genera una clave secreta compartida, la cual es usada para cifrar los datos; e **integridad y autenticación del mensaje,** a partir también de una clave generada en el *Handshake* para generar un MAC.

Este protocolo toma un mensaje de la aplicación que se va a transmitir, lo fragmenta en bloques manejables, opcionalmente los comprime, les añade un MAC y realiza el cifrado, al que añade una cabecera, y transmite la unidad resultante en un segmento TCP; tal como se describe en la siguiente figura.

© Universidad Internacional de La Rioja (UNIR)

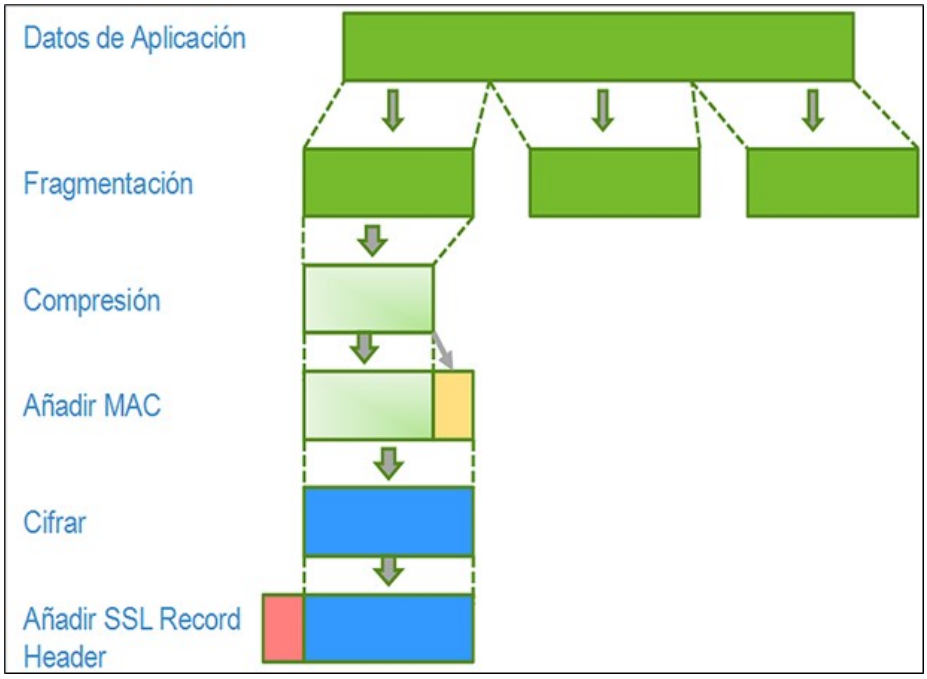


Figura 10. SSL Record Protocol. Elaboración Propia.

SSL Handshake Protocol

Este es el protocolo que permite la autenticación de servidor y cliente, negocia el algoritmo de cifrado, calcula las claves para MAC y las claves simétricas que se utilizarán para proteger los datos que envía luego el SSL Record.

Consiste en una serie de mensajes intercambiados entre servidor y cliente. Cada mensaje tiene tres campos: **tipo, longitud y contenido;** que se describen a continuación:

- **Tipos:** indica uno de los 10 tipos de mensajes posibles:
  - Hello-request.
  - Client-hello.
  - Server-hello.

© Universidad Internacional de La Rioja (UNIR)

- Certificate.
- Server_key_exchange.
- Certificate_request.
- Server_done.
- Certificate_verify.
- Client_key_exchange.
- Finished.

- **Longitud:** especifica la longitud del mensaje en bytes.
- **Contenido:** contiene los parámetros asociados con el mensaje.

El intercambio de mensajes está dividido en cuatro fases y sus correspondientes mensajes (los mensajes marcados con asterisco son opcionales):

© Universidad Internacional de La Rioja (UNIR)

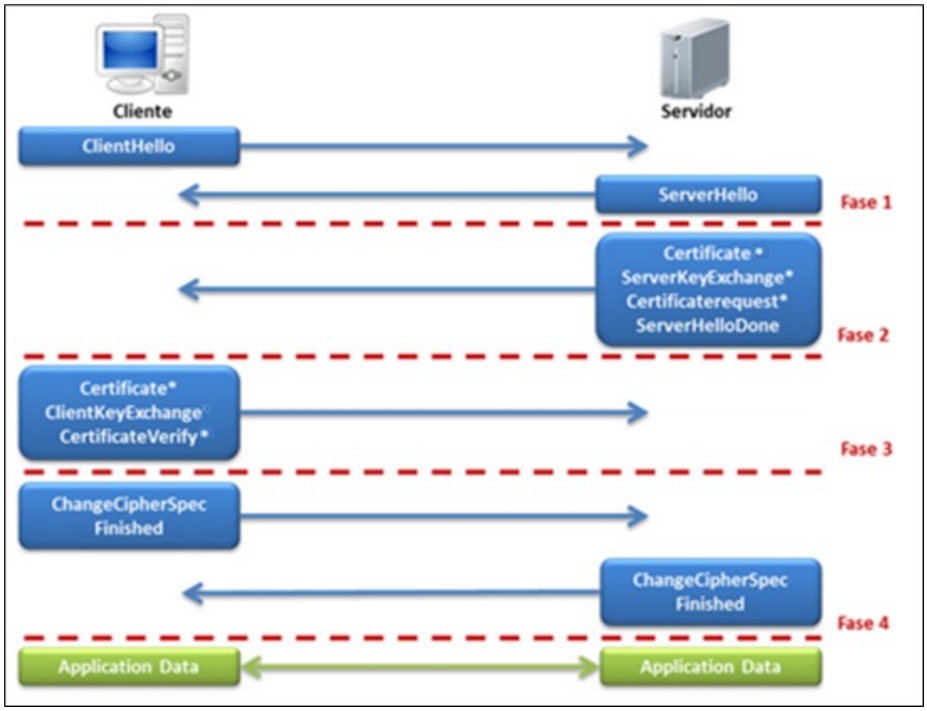


Figura 11. SSL Handshake Protocol. Elaboración Propia.

Primera fase: inicio de la **conexión y establecimiento de las capacidades de cada extremo** (combinaciones de algoritmos permitidos por cada uno). Los mensajes empleados son los siguientes:

- ClientHello
  - Versión del protocolo.
  - Número aleatorio: número generado por el cliente, que consiste en un sello de tiempo. Se utiliza en el intercambio de claves para prevenir ataques de repetición.
  - Identificador de sesión.
  - Lista de algoritmos de cifrado: contiene los algoritmos de cifrado que soporta el cliente.

© Universidad Internacional de La Rioja (UNIR)

- Lista de algoritmos de compresión: contiene los algoritmos de compresión que soporta el cliente.

- ServerHello
  - Versión del protocolo.
  - Número aleatorio: elegido por el servidor para el intercambio de mensajes (distinto al del cliente).
  - Identificador de sesión.
  - Conjunto de algoritmos de cifrado: elegidos por el servidor de la lista que soporta el cliente.
  - Algoritmos de compresión: los elegidos por el servidor de la lista que soporta el cliente.

Segunda fase: en esta fase se lleva a cabo la autenticación del servidor y el intercambio de clave. Los mensajes empleados son los siguientes:

- **Certificate:** certificado x.509 del servidor junto con la cadena de certificados al cliente. Solamente no se usa si cuando se usa SSL en forma anónima.
- **ServerKeyExchange:** solo si es necesario para el intercambio de claves.
- **CertificateRequest:** se envía si el servidor requiere autenticación del cliente.
- **ServerHelloDone:** indica el final del mensaje ServerHello y los mensajes

© Universidad Internacional de La Rioja (UNIR)

relacionados.

Tercera fase: en esta fase se lleva a cabo la autenticación del cliente y el intercambio de clave. Los mensajes empleados son los siguientes:

- **Certificate:** si el servidor solicitó el certificado, debe enviar un certificado en caso de poseerlo; de lo contrario, el servidor negará la conexión o establecerá las políticas que tenga asociadas a este caso.

- **ClientKeyExchange:** el cliente envía cifrado el secreto premaestro con la clave pública del servidor. Es la semilla utilizada para generar el secreto maestro que a su vez será usado para generar el material de claves de la sesión.

La generación del secreto maestro a partir del secreto premaestro y, posteriormente la generación del material de claves de la sesión a partir del secreto maestro tienen un esquema similar. En la siguiente figura se muestra la generación del material de claves a partir del secreto maestro.

© Universidad Internacional de La Rioja (UNIR)

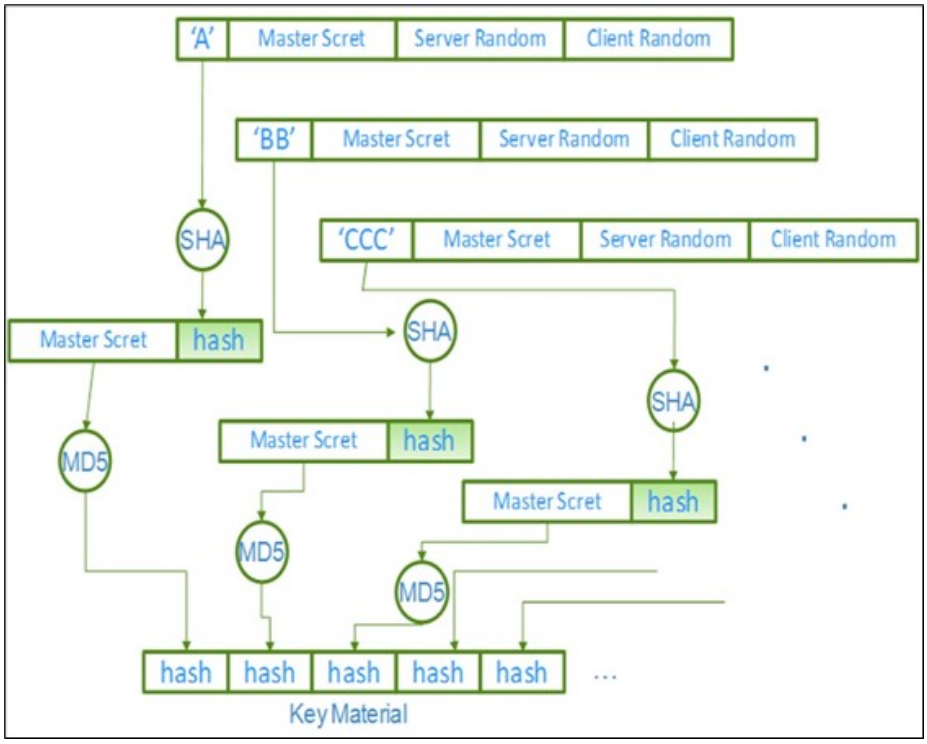


Figura 12. Generación de clave. Elaboración Propia.

Para la generación del secreto maestro a partir del secreto premaestro, simplemente se realizan los pasos 'A', 'BB' y 'CCC'. Sin embargo, para generar el material de claves a partir del secreto maestro generado, se van a realizar las iteraciones necesarias en función de los algoritmos criptográficos que van a ser utilizados para la autenticación y el cifrado.

El cliente y el servidor generan todo el material de clave, pero cada uno utiliza una parte especifica del mismo; tal y como puede verse en la siguiente figura.

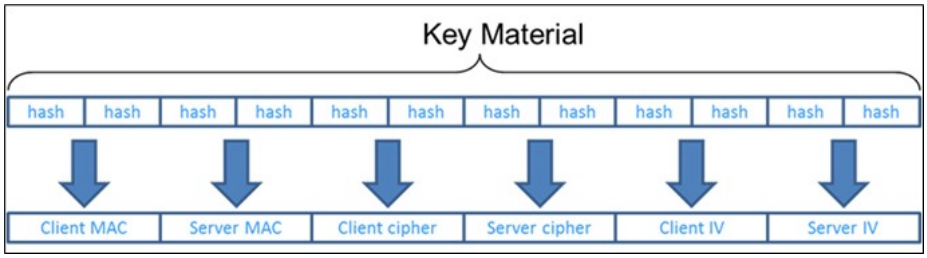


Figura 13. Material de clave. Elaboración Propia.

© Universidad Internacional de La Rioja (UNIR)

- **CertificateVerify:** enviado por el cliente si el servidor ha solicitado su autenticación.

Cuarta fase:

En esta fase finaliza la negociación de parámetros entre cliente y servidor. Los mensajes empleados son los siguientes:

- **ChangeCipherSpec:** el cliente pasa a utilizar los algoritmos y claves negociados: los algoritmos aceptados por el servidor en el mensaje ServerHello y las claves calculadas a partir del secreto premaestro.
- **Finished:** el cliente ha terminado la fase de negociación. Es el primer mensaje cifrado e incluye, entre otros, un resumen del secreto maestro, los mensajes anteriores y una constante. El servidor puede verificar que descifra los mensajes correctamente.
- **ChangeCipherSpec:** el servidor pasa a utilizar los algoritmos y claves negociados.
- **Finished:** el servidor ha terminado la fase de negociación. Envía un mensaje cifrado.

SSL Change Cipher Spec Protocol

Indica que el cliente pasa a utilizar los algoritmos y claves negociados. Algoritmos aceptados por el servidor en el mensaje *ServerHello*, y claves calculadas a partir del secreto premaestro.

Alert Protocol

© Universidad Internacional de La Rioja (UNIR)

Este protocolo gestiona la sesión SSL y los mensajes de error y advertencias (*warning, critical y fatal*). Algunos ejemplos de este tipo de mensajes son:

- Unexpected message.
- Bad record MAC.
- Decompression failure.
- Bad certifícate.
- Certificate revoked.
- Certificate expired.
- Etc.

Datagrama TLS (DTLS)

DTLS es una extensión del protocolo TLS que provee los mismos servicios de seguridad (integridad, autentificación y confidencialidad), pero sobre UDP. El éxito de aplicación que tuvo TLS llevó a generar DTLS para su uso en comunicaciones no orientadas a conexión. DTLS se caracteriza por:

- Negociación de claves sin conexión:
  - Realizado sobre la misma conexión UDP.
  - Se necesita implementar los controles que ofrece TCP.
- Establecimiento de una sesión fiable, control de retransmisiones.

© Universidad Internacional de La Rioja (UNIR)

- Confidencialidad y control de integridad.
- Contempla las limitaciones del tamaño de los mensajes.

Por otro lado, las **principales diferencias de DTLS con TLS** son:

- Los registros no se fragmentan.
- Control de retransmisiones, tiempo (16 bits) y secuencia (48bits); además, DTLS contiene una ventana de antirrepetición.
- Modos de cifrado, no es viable la utilización de RC4 y propone el empleo de CBC con vector de iniciación explícito.
- *Timeout* y retransmisiones, cada nodo mantiene un reloj desde la última retransmisión, depende del RTT que está establecido por defecto entre 500 y 1.000 ms.
- Empleo de cookies para evitar ataques de denegación de servicio (DoS).

En el vídeo, *Ataques a TLS*, se analizan los principales ataques publicados al protocolo.

© Universidad Internacional de La Rioja (UNIR)

8.4. Referencias bibliográficas

Lucena López, M. J. (2022, febrero 11). *Criptografía y Seguridad en Computadoras*. http://criptografiayseguridad.blogspot.com/p/criptografia-y-seguridad-en.html

Stallings, W. (2004). *Fundamentos de seguridad en redes: aplicaciones y estándares*. Pearson Educación.

Feit, S. (1998). TCP-*IP: arquitectura, protocolos e implementación con IPv6 y seguridad de IP*. McGraw-Hill Iberoamericana de España.

© Universidad Internacional de La Rioja (UNIR)

Anatomy and Performance of SSL Processing

Zhao, L., Iyer, R., Makineni, S., y Bhuyan, L. (2005, March). Anatomy and performance of SSL processing. In *IEEE International Symposium on Performance Analysis of Systems and Software, 2005*. ISPASS 2005. (pp. 197-206). IEEE.

En este artículo se realiza un análisis sobre el rendimiento de SSL en las transacciones web seguras.

© Universidad Internacional de La Rioja (UNIR)

IPSec: Performance Analysis and Enhancements

Shue, C. A., Gupta, M., y Myers, S. A. (2007, June). Ipsec: Performance analysis and enhancements. In *2007 IEEE International Conference on Communications (pp. 1527-1532).* IEEE.

En este artículo se realiza un análisis sobre el rendimiento de IPSec en servidores VPN en un entorno con varios clientes.

© Universidad Internacional de La Rioja (UNIR)

Test

1. El uso de la arquitectura IPSEC:

   A. Siempre asegura la confidencialidad de los datos.

   B. Asegura la disponibilidad de los datos.

   C. Las respuestas A y B son correctas.

   D: Ninguna de las anteriores.

2. La cabecera de autenticación (AH):

   A. Solo puede ser empleada cuando los equipos que intervienen en la comunicación implementan IPv6.

   B. Proporciona los tres principales servicios de seguridad (confidencialidad, integridad y disponibilidad).

   C. Proporciona los tres principales servicios de seguridad (autenticación, disponibilidad e integridad).

   D. Ninguna de las anteriores.

3. El protocolo ESP:

   A. Puede proporcionar autenticación e integridad.

   B. Proporciona solo confidencialidad.

   C: Las respuestas A y B son correctas.

   D. Ninguna de las anteriores.

4. El protocolo IKE:

   A. Posee dos fases que están completamente cifradas para la negociación de parámetros de seguridad.

   B. Todos los mensajes de la segunda fase están cifrados.

   C. Las respuestas A y B son correctas.

   D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

5. El protocolo IKE:

A. Durante la fase 1 se establecen los parámetros de protección del protocolo ESP.

B. Durante la fase 1 se establecen los parámetros de protección del protocolo AH.

C. Durante la fase 1 se establecen los parámetros de protección de la siguiente fase IKE.

D. Ninguna de las anteriores.

6. La negociación de claves de la fase 2 del protocolo IKE:

A. Puede ser realizada sin necesidad de la fase 1.

B. Puede no ser necesaria una vez completada la fase 1.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

7. El protocolo SSL:

A. Proporciona autenticación e integridad.

B. Proporciona no repudio.

C. Proporciona solo confidencialidad.

D. Ninguna de las anteriores.

8. El protocolo SSL:

A. El secreto premaestro se compone de información que ha sido generada parte en el cliente y parte en el servidor.

B. El secreto premaestro es generado por el cliente.

C. El secreto premaestro es generado por el servidor.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

9. En el protocolo *handshake* de SSL:

A. Puede llevarse a cabo sin completar la fase de autenticación y el intercambio de claves.

B. Puede llevarse a cabo sin que el servidor posea un certificado de clave pública que pueda ser verificado.

C. Cada uno de los extremos genera las claves que le permitirán alcanzar el servicio de no repudio.

D. Ninguna de las anteriores.

10. Los mensajes de Change cipher Spec de SSL:

A. Se emplean para enviar la clave de sesión generada en el protocolo *handshake* al otro extremo.

B. Son mensajes opcionales.

C. Las respuestas A y B son correctas.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)